Trust / PKI hierarchy

Arrows
Solid black: signs (issuer → leaf)
Dashed blue: trusts (truststore or pin → anchor)
Dashed brown: private key held in the HSM
RMI, USB PROVISION and KME TLS use separate truststores.

SE | SAE | USER (UserApp) | QKD / KME | Trust anchor / pin

Lab PKI: CertGenerator (lab only; production needs its own CA)

SAE root CA (CERTGEN_ROOT_CA, default root-ca)
software ML-DSA, CN=PQC-Root-CA
certs/ca/root-ca.p12 + root-ca.pem

Client CA (CERTGEN_CLIENT_CA, default client_ca)
software ML-DSA, CN=PQC-Client-CA
certs/ca/client_ca.p12 + client_ca.pem

signs
trusts
PROVISION: trusts
signs CLIENT CSR (UserApp INIT LAB; production: external CA)
trusts

SAE node (one per site; SaeNode)

Node leaf certs/{name}.pem
ML-DSA-44, CN = name
issued from the HSM public key

private key

Utimaco HSM (PQMI / CryptoServer)
node ML-DSA key {HSM_MLDSA_GROUP}/{name}
generated in the HSM, non-exportable
QKD client key (alias QKD_HSM_KEY_ALIAS)

RMI truststore
(HsmNodeTls.createContextForNode)
certs/ca/root-ca.pem only
+ spkiSha384 pins (KnownPeers, RmiPeerPinning)

USB PROVISION truststore
(HsmNodeTls.createContextForCommandServer)
certs/ca/client_ca.pem only (device leaves)

Peer SAE leaves (other sites)
accepted only if the chain ends at root-ca
AND the SPKI is pinned

KME truststore QKD_TRUSTSTORE_PATH
KME server CA only; CLASSICAL profile

SAE QKD client cert sae-N-client.p12
signed by the QuKayDee client root CA;
key imported into the HSM by CertGenerator

Client device SE (STM32U535 + TROPIC01)

Device leaf (FLASH_CREDS page 21)
ML-DSA key generated on chip;
CLIENT CSR → INSERT SIGNED CSR

SAE CA (FLASH_CREDS page 21)
trusted for PROVISION only;
written by OWNER SET / CREDS SAE

Owner SPKI pin (NV page 22), used instead of a CA
ENCRYPT / DECRYPT (mTLS) and MANAGE (no device cert)
the device stores no client CA

trusts
pins
trusts

USER: UserApp (home PC, no HSM)

Owner leaf certs/user/user.p12
ML-DSA; this key is the device owner

Truststore certs/ca/client_ca.pem
checks the device leaf on
ENCRYPT / DECRYPT

signs

QKD / KME PKI (QuKayDee; separate from the SAE PKI)

QuKayDee client root CA
client-root-ca.crt (QKD/qukaydee-generate-client-certificates), uploaded to QuKayDee

KME server CA
downloaded from QuKayDee
certs/qkd/qkd-server-ca.p12 (public only)

signs

KME server leaf
QuKayDee KME, ETSI 014 API

trusts